KnowledgeOS Enterprise Test Data — Security Incident Response Plan

Field	Value
Version	3.5
Classification	RESTRICTED - SECURITY TEAM & LEADERSHIP
Effective Date	April 1, 2024
Last Reviewed	March 15, 2024
Document Owner	Chief Information Security Officer (CISO)
Review Cycle	Semi-Annual + Post-Incident
Regulatory References	NIST SP 800-61 Rev. 2, ISO 27001 A.16, SOC 2 CC7, GDPR Art. 33/34, NYDFS 500.17, PCI DSS 12.10

---

1. Purpose & Scope

This Security Incident Response Plan (IRP) defines the structured approach for detecting, responding to, and recovering from information security incidents at TechGlobal Solutions Inc. ("Company"). It applies to all Company information systems, networks, data, personnel, and third-party services processing Company data.

Objectives:

- Minimize impact: Contain threats, reduce dwell time, limit data exposure
- Ensure compliance: Meet regulatory notification requirements (72 hrs GDPR, etc.)
- Preserve evidence: Support legal, forensic, insurance, regulatory needs
- Enable recovery: Restore operations securely, validate integrity
- Improve posture: Lessons learned → preventive controls

2. Incident Classification

2.1 Severity Levels

Level	Name	Criteria Examples	SLA (Contain)	Notification
SEV-1	Critical	Active ransomware, confirmed data exfiltration, production DB breach, critical vuln exploited (CVSS⩾9), widespread service outage	1 hour	Immediate (CISO, CEO, Legal, Board)
SEV-2	High	Malware on corp endpoints, phishing with credential compromise, unauthorized admin access, cloud config exposing PII	4 hours	2 hours (CISO, Legal, VP Eng, Comms)
SEV-3	Medium	Failed intrusion attempts, policy violations (shadow IT, data mishandling), lost unencrypted device, brute force locked accounts	24 hours	8 hours (Security, Manager)
SEV-4	Low	Phishing reported (no click), vulnerability scan findings, policy questions, minor config drift	72 hours	Next business day (Security)

2.2 Data Impact Classification

- NONE: No personal/confidential data involved
- LOW: Internal-only data (org charts, public marketing)
- MEDIUM: CONFIDENTIAL business data (financials, roadmaps, contracts)
- HIGH: RESTRICTED data (PII, PHI, credentials, encryption keys, trade secrets)
- CRITICAL: Regulated data (PCI, HIPAA, GDPR special category) + evidence of exfiltration

3. Incident Response Team (IRT)

3.1 Core Team (Always Activated)

Role	Primary	Backup	Responsibilities
Incident Commander (IC)	CISO / Sr. Sec Manager	Sec Operations Lead	Authority, decisions, comms, escalation

Technical Lead	Sr. Security Engineer	SOC Analyst Lead	Containment, eradication, forensics
Communications Lead	VP Communications	Comms Manager	Internal/external messaging, regulator liaison
Legal Liaison	Deputy General Counsel	Privacy Counsel	Legal obligations, privilege, law enforcement
Business Liaison	VP Engineering / CTO	Engineering Director	Service impact, recovery prioritization
Scribe	Security Analyst	Rotating	Timeline, decisions, evidence log

3.2 Extended Team (As Needed)

- Forensics: Mandiant/CrowdStrike retainer (4-hour SLA)
- Cloud: AWS/Azure/GCP TAMs + Solutions Architects
- Identity: Okta/AD admins, IAM team
- Data: DPO, Data Engineering, Database Admins
- HR: For insider threats, employee involvement
- Facilities: Physical access, badge logs
- Executive: CEO, CFO, General Counsel (SEV-1 only)

3.3 Activation Authority

- SEV-1: CISO, CEO, or General Counsel (any one)
- SEV-2: CISO, Security Director, or SOC Lead
- SEV-3/4: SOC Analyst or Security Manager

4. Incident Response Lifecycle

4.1 Phase 1: Preparation (Continuous)

- IR Plan maintenance, tabletop exercises (quarterly), red team (annual)
- Tooling: SIEM (Splunk/Chronicle), EDR (CrowdStrike), NDR (Corelight), SOAR (Cortex XSOAR)
- Playbooks: 50+ automated playbooks (phishing, malware, credential theft, cloud, ransomware)

- Threat Intel: Mandiant, IBM X-Force, ISAC feeds → IOC enrichment
- Logging: Centralized (13 months hot), tamper-proof (WORM), correlated
- Evidence: Chain of custody procedures, forensic workstations, write-blockers

4.2 Phase 2: Detection & Analysis

4.2.1 Detection Sources

- Automated: SIEM alerts, EDR detections, cloud guard duties, DLP, UEBA
- Manual: User reports (phish@, security@), vendor notifications, threat intel
- Hunt: Scheduled threat hunts (MITRE ATT&CK aligned)

4.2.2 Triage Process (SOC 24/7)

- Enrichment: IOC lookup, asset context, user context, MITRE mapping
- Scoring: Severity + Data Impact → Classification (Section 2)
- Escalation: Auto-page for SEV-1/2; queue for SEV-3/4
- False Positive Rate Target: < 5% (tuning continuous)

4.2.3 Initial Analysis (First 30 min)

- Scope: Affected assets, accounts, data, network segments
- Vector: Initial access (phish, exploit, credential, insider, supply chain)
- Persistence: Scheduled tasks, services, run keys, cloud IAM, containers
- Lateral: RDP, SMB, SSH, Pass-the-Hash, cloud console, CI/CD
- Collection: Memory, disk, logs, network captures (preserve first!)

4.3 Phase 3: Containment

4.3.1 Short-Term (Immediate - Limit Spread)

- Network: Quarantine VLAN, block C2 IPs/domains at firewall/proxy
- Endpoint: EDR isolate (network disconnect, retain memory)
- Identity: Disable compromised accounts, revoke sessions, rotate keys
- Cloud: Security groups, IAM policies, detach volumes, snapshot
- SaaS: Revoke OAuth tokens, disable API keys, force re-auth

4.3.2 Evidence Preservation (Before Containment Where Possible)

- Memory capture (WinPMEM, LiME, AWS/GCP/Azure snapshots)
- Disk images (FTK Imager, dd, cloud snapshots)

- Log exports (SIEM, cloud trails, Okta, firewall)
- Chain of custody: Hash (SHA-256), sign, seal, log

4.3.3 Long-Term (Recovery Preparation)

- Rebuild vs. Clean: Rebuild preferred (golden images, IaC)
- Segmentation: Micro-segmentation, zero trust enforcement
- Monitoring: Enhanced logging, deception (canaries), honeypots

4.4 Phase 4: Eradication

- Root Cause Identification: RCA mandatory for SEV-1/2
- Malware Removal: Complete removal + persistence mechanism elimination
- Vulnerability Patching: Emergency change process (bypass CAB with CISO approval)
- Credential Rotation: All potentially compromised (service accounts, keys, certs)
- Configuration Hardening: Remove unnecessary access, enforce least privilege
- Verification: Re-scan, penetration test, threat hunt before recovery

4.5 Phase 5: Recovery

4.5.1 Prioritization (Business Liaison + IC)

- Tier 0: Life safety, revenue-critical (payments, core API)
- Tier 1: Customer-facing production
- Tier 2: Internal business systems
- Tier 3: Development/test, non-critical

4.5.2 Restoration Process

- Validate backups: Integrity checks, malware scan, test restore
- Staged recovery: Isolated VLAN → validation → production cutover
- Monitoring: 30-day enhanced monitoring (Level 1 SOC watch)
- Sign-off: Technical Lead + Business Owner + Security

4.6 Phase 6: Post-Incident Activity

4.6.1 Post-Mortem (Within 14 Days)

- Blameless culture: Focus on systems, not individuals
- Template: Timeline, root cause, impact, detection gap, response gap, improvements
- Participants: IRT + affected teams + management

- Output: Action items (Jira epics) with owners, due dates, severity

4.6.2 Metrics Tracking

- MTTD: Mean Time to Detect (Target: < 1 hr SEV-1, < 4 hr SEV-2)
- MTTA: Mean Time to Acknowledge (Target: < 15 min)
- MTTC: Mean Time to Contain (Target: Per SLA Section 2.1)
- MTTR: Mean Time to Recover (Target: < 4 hr Tier 0, < 24 hr Tier 1)
- Recurrence Rate: Same root cause within 12 months (Target: 0)

4.6.3 Improvement Implementation

- Tracked in Jira "Security Improvements" project
- Monthly review by CISO; quarterly by Audit Committee
- Closure requires: Implementation + validation + documentation update

5. Specific Playbooks (High-Level)

5.1 Ransomware

- Immediate: Isolate affected segments, DO NOT power off (memory forensics)
- Negotiation: Prohibited without CEO + GC + Board approval (insurance coordinates)
- Recovery: Offline backups (air-gapped, immutable), staged restoration
- Reporting: FBI IC3, CISA, insurer, regulators (if data exfiltrated)

5.2 Business Email Compromise (BEC)

- Detect: Impossible travel, forwarding rules, OAuth app consent, mailbox delegation
- Contain: Disable account, revoke tokens, remove rules/apps, MFA re-enroll
- Assess: Email search (eDiscovery), forwarding history, accessed data
- Notify: Finance (wire fraud risk), customers/partners if impersonated

5.3 Cloud Security Incident (AWS/Azure/GCP)

- Detect: GuardDuty, Security Hub, Defender for Cloud, CloudTrail anomalies
- Contain: IAM policy deny, security group restrict, snapshot volumes
- Investigate: CloudTrail, VPC flow logs, container runtime (Falco)
- Coordinate: Cloud provider support (Enterprise/Business tier)

5.4 Supply Chain / Third-Party Incident

- Vendor notification: Security@ vendor + contractual contacts
- Assess: Data shared, access granted, vendor's blast radius
- Contain: Revoke vendor access, rotate shared secrets, review logs
- Contract: Invoke incident response clauses, liability, termination rights

5.5 Insider Threat

- Detect: DLP, UEBA, HR referral, whistleblower, exit monitoring
- Legal + HR lead; Security supports forensics only
- Preserve: Chain of custody critical for legal admissibility
- Proportional response: Access revocation → investigation → disciplinary/legal

6. Communication Protocols

6.1 Internal Communication

- SEV-1: Slack #security-incident-sev1 (auto-created), Bridge call (Zoom) within 15 min
- Status updates: Every 30 min (SEV-1), hourly (SEV-2), 4-hourly (SEV-3)
- Executive brief: Every 2 hours (SEV-1), per request (SEV-2)
- All-hands: Only if customer-facing impact or major reputational risk

6.2 External Communication

- Customers: Only confirmed facts; no speculation; coordinated by Comms + Legal
- Regulators: Legal drafts; DPO for privacy; CISO for security
- Law Enforcement: GC authorizes; FBI/Secret Service for financial/cyber
- Media: Comms only; holding statement within 2 hours (SEV-1)
- Insurance: Broker notified within 4 hours (SEV-1/2); claim initiated

6.3 Communication Templates (Pre-Approved)

- Customer notification (data breach, service outage)
- Regulator notification (GDPR, NYDFS, sector-specific)
- Employee FAQ (internal)
- Press holding statement
- Vendor/partner notification

7. Evidence Handling & Forensics

7.1 Chain of Custody

- Form: Digital (ServiceNow) + Physical (tamper-evident bags)
- Fields: Case ID, Item description, Collector, Date/Time, Location, Hash, Seal #
- Transfer: Signed handoff at each step; minimum handlers
- Storage: Evidence safe (physical) / Encrypted S3 with Object Lock (digital)

7.2 Forensic Readiness

- Images: Golden images for all standard builds (verified clean)
- Tools: Magnet AXIOM, EnCase, Velociraptor, KAPE, Volatility, Plaso
- Cloud: Native snapshots + forensic exports (AWS IR, Azure Sentinel, GCP FTL)
- Retention: Evidence held until legal release + 1 year

7.3 Legal Hold

- Issued by Legal; overrides retention/destruction
- Applies to: All potentially relevant data (logs, emails, chats, code, docs)
- Tracking: Legal hold portal; quarterly compliance attestation
- Release: Written authorization from Legal only

8. Regulatory Notification Requirements

Regulation	Trigger	Timeline	Authority
GDPR Art. 33	Personal data breach	72 hrs	Lead SA (Ireland DPC)
GDPR Art. 34	High risk to rights/freedoms	Without delay	Data subjects
CCPA § 1798.150	PI breach (CA residents)	Expedited	CA AG (if >500 affected)
NYDFS 500.17	Cybersecurity event (financial)	72 hrs	NYDFS
HIPAA	PHI breach	60 days	HHS OCR (+ media if >500)
PCI DSS 12.10	Cardholder data compromise	72 hrs	Card brands, acquirers

SEC (public cos)	Material cybersecurity incident	4 business days	Form 8-K Item 1.05
State breach laws	PII breach (varies by state)	Varies	State AGs

9. Tools & Infrastructure

9.1 Core Platform

- SIEM: Splunk Enterprise Security + Chronicle (dual-write)
- SOAR: Cortex XSOAR (50+ playbooks, auto-enrichment, case management)
- EDR: CrowdStrike Falcon (Complete)
- NDR: Corelight (Zeek + Suricata)
- Cloud: AWS Security Hub, Azure Defender, GCP SCC
- Identity: Okta (IdP), CyberArk (PAM), Microsoft Entra ID
- Vulnerability: Tenable.io, Qualys, Trivy (container)
- Threat Intel: Mandiant Advantage, AlienVault OTX, ISAC feeds

9.2 Forensic Lab

- Workstations: 2x FRED (Digital Intelligence), 2x Mac forensic
- Write-blockers: Tableau, WiebeTech
- Mobile: Cellebrite UFED, Magnet GRAYKEY
- Network: Packet capture (Endace), NetFlow (Plixer)
- Cloud: Forensic VPCs (isolated, logging-enabled)

10. Training & Exercises

10.1 Tabletop Exercises (Quarterly)

- Scenarios: Ransomware, BEC, Cloud breach, Supply chain, Insider
- Participants: IRT + Extended Team + Executives (annual)
- Facilitator: External (alternate years) / Internal
- After-action: Report + improvement tracking

10.2 Technical Drills (Monthly)

- Playbook execution: Phishing, malware, credential theft, cloud

- Red team: Annual (external); Purple team: Quarterly
- Recovery test: Quarterly (critical systems), Annual (full DR)

10.3 Training Requirements

- IRT: SANS FOR500/508/572, GCFA/GNFA/GCTI certifications
- SOC: SANS SEC450/503, GCIA/GCIH
- All staff: Annual security awareness (includes reporting)

11. Metrics & KPIs

Metric	Target	Measurement	Reporting
MTTD (SEV-1)	< 1 hour	SIEM alert → ticket	Monthly
MTTA (SEV-1/2)	< 15 min	Ticket → analyst ack	Monthly
MTTC (SEV-1)	< 1 hour	Ticket → containment	Monthly
MTTR (Tier 0)	< 4 hours	Contain → restore	Monthly
False Positive Rate	< 5%	FP / Total alerts	Monthly
Playbook Coverage	100% top 20	MITRE ATT&CK mapped	Quarterly
Tabletop Completion	100% IRT	Attendance	Quarterly
Action Item Closure	90% $\leqslant$ 90 days	Jira tracking	Monthly

12. Budget & Resources

- IR Retainer: Mandiant $(500K/yr) + CrowdStrikeServices$(200K/yr)
- Forensic Tools: $150K/yr licenses + hardware refresh (3-year cycle)
- Training: $200K/yr (certifications, conferences, exercises)
- Cyber Insurance: $2Mlimit$,250K retention (covers IR, legal, notification, regulatory)

13. Related Documents

- IT Acceptable Use Policy
- Data Privacy & Protection Policy
- Business Continuity & Disaster Recovery Plan

- Vulnerability Management Policy
- Threat Intelligence Program Charter
- Digital Forensics Procedure Guide
- Evidence Handling Procedure
- Regulatory Notification Procedures (per jurisdiction)
- Cyber Insurance Policy Summary

14. Definitions

- **IOC:** Indicator of Compromise
- **TTP:** Tactics, Techniques, Procedures (MITRE ATT&CK)
- **C2:** Command and Control
- **EDR:** Endpoint Detection and Response
- **NDR:** Network Detection and Response
- **SOAR:** Security Orchestration, Automation and Response
- **UEBA:** User and Entity Behavior Analytics
- **PAM:** Privileged Access Management
- **RCA:** Root Cause Analysis
- **MTTD:** Mean Time to Detect
- **MTTA:** Mean Time to Acknowledge
- **MTTC:** Mean Time to Contain
- **MTTR:** Mean Time to Recover/Restore
- **SA:** Supervisory Authority (GDPR)
- **DPC:** Data Protection Commission (Ireland)

15. Revision History

Version	Date	Author	Description
3.5	2024-04-01	CISO Office	Added cloud playbooks, updated reg timelines, enhanced metrics, ransomware negotiation
3.4	2023-10-15	CISO Office	SOAR integration, automated playbooks, evidence handling, legal privilege

3.3	2023-04-01	CISO Office	NIST 800-61 Rev. 2 alignment, GDPR Art. 33/34
3.2	2022-10-01	SecOps	Ransomware playbook, insider threat, comms

---

END OF DOCUMENT

This document contains sensitive security procedures. Distribution is limited to authorized personnel only. Unauthorized disclosure may compromise incident response capabilities. Handle per Information Classification Policy (RESTRICTED).